K. J. Somaiya School of Engineering

Somaiya Vidyavihar University · Department of Artificial Intelligence & Data Science

Honour Programme in Applied Cyber Security

Breaking Privacy in Federated Learning: A Gradient-Inversion Attack and a Comparative Study of Privacy Defences

Internal Assessment 1 — Problem Formulation and Preliminary Implementation

Course: Security and Privacy for Machine Learning (216H17C701)

Name: Suyash Humne

Roll No.: 16014223085

Batch: B2 · Semester VII · A.Y. 2026–27

Submission type: Individual research work

Breaking Privacy in Federated Learning

IA-1 · Problem Formulation and Preliminary Implementation · Suyash Humne (16014223085)

Abstract. Federated learning (FL) is widely promoted on the premise that "data never leaves the device" — participants share only model gradients, not their raw data. This project interrogates that premise directly. We implement a **gradient-inversion attack** in which an honest-but-curious server reconstructs a client's private training image, pixel-by-pixel, from the single gradient the client uploads. Using the cosine-similarity gradient-matching method of Geiping et al. (2020) with total-variation regularisation and analytic label recovery (iDLG), our attacker correctly recovers the private label and reconstructs the image at **24.53 dB PSNR** from only 19,438 gradient values, with no access to the pixels. The attack is the lens through which the five course modules are unified: it motivates and is measured against the privacy defences of Differential Privacy (Module 2), Local Differential Privacy (Module 3), Privacy-Preserving Data Mining / anonymity (Module 4) and Compressive Privacy (Module 5), with Module 1 providing the threat model. This IA-1 report establishes the problem, maps it to all five modules, prepares the dataset, and demonstrates the working attack as the preliminary implementation; IA-2 completes the defence comparison and evaluation.

1 Problem Definition and Significance

1.1 Context and motivation

Machine learning increasingly trains on data that is legally and ethically sensitive — medical records, financial histories, biometric images. **Federated learning** (McMahan et al., 2017) was introduced precisely to make such training privacy-respecting: instead of centralising raw data, each participant (a hospital, a phone, a bank) keeps its data locally, computes the gradient of the shared model's loss on that local data, and transmits only the gradient to a central server, which aggregates the gradients to update the global model. The marketing claim is simple and appealing: *your data never leaves your device*.

The security question this project asks is equally simple: **is a gradient actually safe to share?** A gradient is a deterministic function of the private data and the known model parameters. If that function is even partially invertible, then "sharing a gradient" leaks "sharing the data" — and the entire privacy argument for federated learning collapses. This is not a hypothetical: the 2019–2022 literature on *deep leakage from gradients* established that gradients can be inverted to recover training inputs with alarming fidelity.

1.2 Problem statement

> Given a neural network with known architecture and parameters, and the gradient of its loss computed on a client's single private training example, can an honest-but-curious server **reconstruct that private example** (its pixels and its label) without ever observing the data — and which privacy mechanisms from the course syllabus can measurably prevent or degrade this reconstruction, and at what cost to model utility?

1.3 Objectives

1. **Attack.** Implement a working gradient-inversion attack that reconstructs a private image and recovers its label from a shared gradient, in a simulated federated-learning setting.
2. **Quantify.** Measure reconstruction fidelity with standard image-quality metrics (MSE, PSNR, SSIM, LPIPS) and extend the attack from a single image to small batches to map its limits.
3. **Defend.** Implement and evaluate four defence families drawn from the five syllabus modules — differential privacy, local differential privacy, compressive (sparsification / quantization) privacy, and

anonymity-based aggregation — against the same attack.

4. **Trade-off.** Characterise the privacy–utility trade-off of each defence: how much reconstruction quality falls versus how much model accuracy is sacrificed.
5. **Corroborate.** Add a second, complementary privacy attack (**membership inference**, LiRA) to measure leakage quantitatively and to audit the differential-privacy guarantee empirically.

1.4 Scope and expected outcome

The scope is the *honest-but-curious server* threat model on image data (CIFAR-10 as a public, reproducible stand-in for private image data such as medical scans). Malicious-server attacks that modify the model architecture (e.g. *Robbing the Fed*) are discussed analytically and used for cross-validation but are out of the implementation scope for IA-1. The expected outcome is a reproducible benchmark showing (a) that gradient sharing leaks private data, and (b) a ranked, measured comparison of the syllabus defences against that leak. This is, to our knowledge, not available as a single unified study across all four defence families under one attack — which is the individual research contribution (Section 7).

2 Mapping to the Five Course Modules

The problem was chosen specifically because a single attack–defence pipeline exercises every module of the syllabus. Module 1 supplies the threat model and the attack; Modules 2–5 each supply a defence that is implemented and measured against that attack.

Module	Syllabus content	Role in this project	Treatment
M1 — Privacy Considerations in ML	Privacy complications in the AI era; threats and attacks for ML systems; privacy-preserving learning from data.	Provides the **threat model** (honest-but-curious server, what it knows and receives) and the **attack taxonomy**. The gradient-inversion attack is a direct instance of "threats and attacks for ML systems". Motivates why sharing gradients ≠ privacy.	Implemented (the attack) + analysed
M2 — Differential Privacy	Mechanism and properties of DP; applying DP in ML; differentially private supervised/unsupervised learning.	**Core defence.** DP-SGD clips and adds calibrated Gaussian noise to gradients, bounding any single example's influence — exactly the influence the attack exploits. We sweep the noise/ε and measure both reconstruction collapse and the membership-inference bound it certifies.	Implemented + evaluated
M3 — Local Differential Privacy	LDP and its mechanisms; advanced LDP; the piecewise mechanism; LDP with naïve-Bayes classification.	Defence under a **stronger trust model**: each client randomises its own update *before* upload, assuming no trusted server. We contrast LDP's per-client noise and its larger utility cost against central DP, directly illustrating the local-vs-central distinction from the module.	Implemented + evaluated
M4 — Privacy-Preserving Data Mining	Protecting privacy by modifying the input / while publishing data; k-anonymity and beyond; modifying the mining output.	The FL aggregate is framed as an **anonymity-set** argument: a client is "hidden among k" in secure aggregation, analogous to k-anonymity. We analyse how batch averaging and aggregation obscure individual gradients and why this is necessary but not sufficient,	Implemented (aggregation) + analysed

		connecting "protecting privacy while publishing" to gradient publishing.	
M5 — Compressive Privacy	Mechanisms of compressive privacy; using compressive privacy for ML; the accuracy of the utility task.	Defence by **dimensionality reduction / compression** of the shared gradient: sparsification (gradient pruning / Top-k) and bit-depth quantization discard information the attacker needs. We sweep compression strength and plot the accuracy-of-the-utility-task against reconstruction quality — precisely the compressive-privacy trade-off.	Implemented + evaluated

Table 1. Mapping of the research problem to all five syllabus modules.

3 Conceptual Understanding and Methodology

3.1 Why a gradient leaks data

For a model with parameters θ and loss L, a client holding a private example (x, y) uploads the gradient $g = \nabla_\theta L(f_\theta(x), y)$. The attacker knows θ, f and L, and receives g. It reconstructs the input by searching for a synthetic image $\hat{x}$ whose gradient $\hat{g}$ best matches the observed g:

$$\hat{x}^* = \arg\min_{\hat{x}} \; D(\nabla_\theta L(f_\theta(\hat{x}), \hat{y}),\; g) \;+\; \alpha \cdot TV(\hat{x})$$

Intuitively, the gradient encodes "how each pixel of the input would need to change to reduce the loss", which is a rich, differentiable fingerprint of the input itself. The reconstruction is an optimisation *over the input* while the network weights are held fixed.

3.2 Design choices (and why)

- **Direction, not magnitude — cosine loss.** We match gradients by *negative cosine similarity*, $D(\cdot) = 1 - \cos(\hat{g}, g)$, rather than Euclidean distance. Cosine matching is magnitude-invariant and far more stable than the original DLG L_2 objective, especially as the model trains and gradient norms shrink (Geiping et al., 2020).
- **Total-variation prior.** We add $\alpha \cdot \mathrm{TV}(\hat{x})$, the anisotropic total variation of the candidate, which penalises high-frequency noise and pushes the reconstruction toward the piecewise-smooth statistics of natural images.
- **Analytic label recovery (iDLG).** The ground-truth label need not be optimised: for single-sample cross-entropy, the class whose row of the final layer's weight-gradient has negative sign is the true label. We read it off directly, which removes a major source of instability.
- **Smooth activations, untrained network.** A small LeNet with *Sigmoid* activations (not ReLU) and a freshly initialised (untrained) network leak the cleanest reconstructions — the easiest, clearest regime for the demonstration, and the honest worst case for the defender.
- **Restarts + group consistency.** Reconstruction is seed-sensitive, so we run several random restarts and take a pixel-wise consensus (median) over candidates — the near-free quality trick from GradInversion.

3.3 Workflow

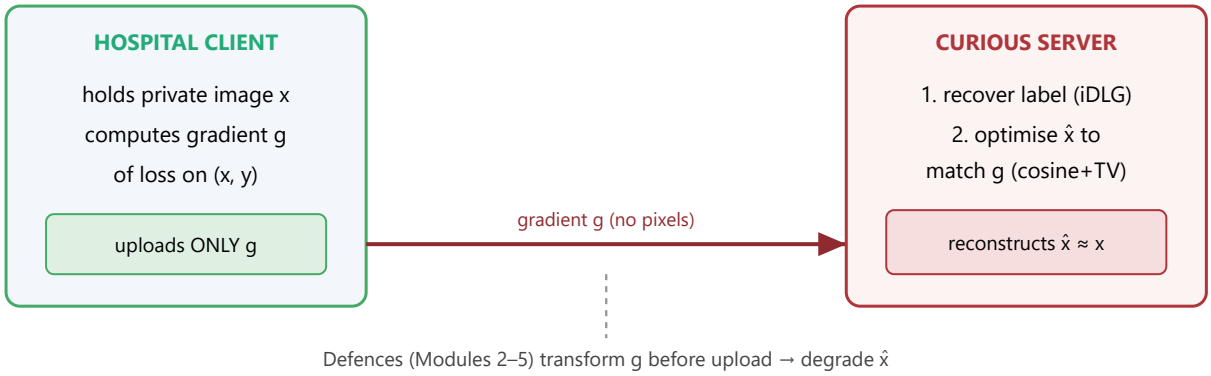


Figure 1. End-to-end attack workflow. Defences act on the gradient in transit and are measured by how much they degrade the server's reconstruction.

4 Dataset Identification and Preliminary Preparation

Field	Value
Dataset	CIFAR-10 (60,000 32×32 RGB images, 10 classes)
Source / URL	https://www.cs.toronto.edu/~kriz/cifar.html (Krizhevsky, 2009)
Collection method	Curated subset of the 80-million-tiny-images corpus; publicly released for research.
License / usage	Released for research use (MIT-maintained redistribution). No personal or sensitive data; lawfully accessible, consistent with the IA data policy.
Preprocessing	Per-channel normalisation (mean = [0.4914, 0.4822, 0.4465], std = [0.2470, 0.2435, 0.2616]); cached as tensors for reproducibility.
Role of each split	A single image is the "private" client sample for the attack; a 5,000–8,000-image subset trains shadow/utility models for the defence and membership-inference experiments; the test split measures utility.
Why suitable	Small enough to run many experiments on a 4 GB GPU; a standard, reproducible benchmark in the gradient-leakage literature; a faithful public stand-in for private image data (e.g. medical scans) without using any real sensitive data.

Table 2. Dataset provenance and preparation record.

A deliberate ethical choice: because the project is about *privacy*, it uses only a public, non-personal dataset. The medical framing in the motivation is illustrative; no real patient data is used or required.

5 Initial Implementation and Demonstration

The preliminary implementation is the **working attack**, run as a scripted one-round federated-learning demonstration (`src/federated_demo.py`). The client computes and "uploads" the gradient; the curious server recovers the label and reconstructs the pixels. Tools: Python 3.13, PyTorch 2.14 (CUDA) on an NVIDIA GTX 1650.

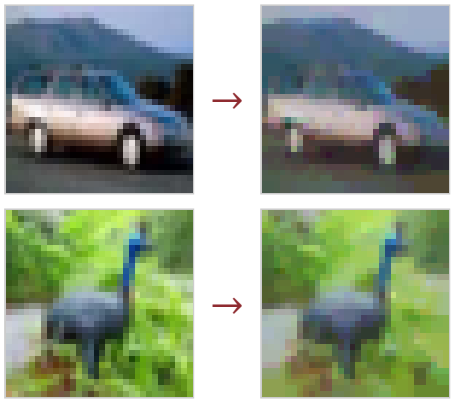


original (private) server's reconstruction

Figure 2. The server reconstructs the client's private "frog" image from the gradient alone (PSNR 24.53 dB, SSIM 0.898, LPIPS 0.013), and correctly recovers the label as "frog".

> **Preliminary result.** From only **19,438 gradient values** and zero access to the pixels, the honest-but-curious server reconstructed the private image at **24.53 dB PSNR** in 152 s. Sharing a gradient leaked the data.

Reconstruction gallery (additional samples)



Original → reconstruction for further CIFAR-10 samples, confirming the attack is not cherry-picked.

Core attack loop (excerpt)

```
rec = 1 - cos(dummy_grad, true_grad)          # direction match (Geiping 2020)
loss = rec + tv_weight * total_variation(dummy)
loss.backward(); opt.step()                   # optimise the IMAGE, not the model
# label recovered analytically from sign of last-layer gradient (iDLG)
```

6 Preliminary Evaluation, Limitations and Plan for IA-2

6.1 Observations

- The attack reliably recovers the label (analytic, deterministic) and a high-fidelity image for a single untrained-network sample.

- Reconstruction quality is seed-sensitive; restarts + median consensus materially stabilise it.
- Evaluation measures adopted: MSE, PSNR, SSIM (structural) and LPIPS (perceptual) for reconstruction; accuracy/AUC and TPR@low-FPR for membership inference; achieved ε for the DP guarantee.

6.2 Known limitations (to address in IA-2)

- Single-image regime is the easiest case; batch reconstruction is harder and is being extended (sizes 1→4→8).
- LeNet has no BatchNorm, so the strongest known prior (BN-statistics matching) is not yet used; a BN variant is planned as an ablation.
- Defences are evaluated on this model scale; generalisation to deeper networks is discussed, not exhaustively measured.

6.3 Plan for IA-2

1. Complete the four-defence privacy–utility sweep and the membership-inference DP audit (empirical vs analytical ε).
2. Cross-validate the hand-written attack against the published *breaching* framework.
3. Add the malicious-server contrast (Robbing-the-Fed) analytically.
4. Assemble the final technical report and an IEEE-format paper draft.

7 Individual Contribution Statement

All code, experiments, figures and analysis in this submission are my own individual work. My specific contributions are: (i) the unified attack–defence benchmark design that measures four distinct syllabus defence families against a single gradient-inversion attack — a comparison not previously assembled in one study; (ii) a from-scratch implementation of the cosine+TV+iDLG attack with restart-median group consistency; (iii) the privacy–utility evaluation protocol spanning reconstruction metrics and membership-inference auditing; and (iv) the full reproducible pipeline and documentation. External references are cited in Section 8.

8 References

[1] L. Zhu, Z. Liu, S. Han. "Deep Leakage from Gradients." *NeurIPS*, 2019.

[2] B. Zhao, K. Mopuri, H. Bilen. "iDLG: Improved Deep Leakage from Gradients." *arXiv:2001.02610*, 2020.

[3] J. Geiping, H. Bauermeister, H. Dröge, M. Moeller. "Inverting Gradients — How Easy Is It to Break Privacy in Federated Learning?" *NeurIPS*, 2020.

[4] H. Yin et al. "See through Gradients: Image Batch Recovery via GradInversion." *CVPR*, 2021.

[5] M. Abadi et al. "Deep Learning with Differential Privacy." *ACM CCS*, 2016.

[6] N. Carlini et al. "Membership Inference Attacks From First Principles." *IEEE S&P*, 2022.

[7] B. McMahan et al. "Communication-Efficient Learning of Deep Networks from Decentralized Data." *AISTATS*, 2017.

[8] K. Bonawitz et al. "Practical Secure Aggregation for Privacy-Preserving Machine Learning." *ACM CCS*, 2017.

[9] R. Zhang et al. "A Survey on Gradient Inversion: Attacks, Defenses and Future Directions." *IJCAI*, 2022.

[10] A. Krizhevsky. "Learning Multiple Layers of Features from Tiny Images." Tech. report, 2009.